

Module 9 — Question Pool

OMSCS 6250 Computer Networks

Lesson 9: Internet Security

Properties of Secure Communication

Q1. [MCQ]

Consider the following scenario: Two users exchange email over an open coffee-shop Wi-Fi network without encryption. An attacker connected to the same network passively sniffs and records the packets and is able to read the full text of every message. Which property of secure communication is violated?

- A. Confidentiality — only the two communicating parties should be able to read the message.
- B. Integrity — the message must not be modified, inserted into, or deleted while in transit.
- C. Authentication — each party must be able to verify that the other is who they claim to be.
- D. Availability — the information or service must remain reachable to legitimate users.

Correct answer: **A**

Why: Confidentiality ensures a message is available only to the intended sender and receiver. Passive eavesdropping/sniffing that lets an attacker read the plaintext breaks confidentiality; encrypting the message is the standard countermeasure.

Q2. [MCQ]

Scenario: A customer sends a bank-transfer request to their bank. A man-in-the-middle intercepts the message and changes the destination account number before forwarding it on. The message is still delivered and still comes from the real customer, but its contents were altered in transit. Which property of secure communication is violated?

- A. Confidentiality — only the two communicating parties should be able to read the message.
- B. Integrity — the message must not be modified, inserted into, or deleted while in transit.
- C. Authentication — each party must be able to verify that the other is who they claim to be.
- D. Availability — the information or service must remain reachable to legitimate users.

Correct answer: **B**

Why: Integrity ensures a message is not modified, inserted into, or deleted while in transit. Altering the message contents in flight breaks integrity, even though the message is still delivered and the sender's identity is genuine.

Q3. [MCQ]

Scenario: An attacker stands up a server that impersonates a user's bank. The user connects and, believing they are talking to the real bank, enters their credentials — but the party on the other end is not who it claims to be. Which property of secure communication is violated?

- A. Confidentiality — only the two communicating parties should be able to read the message.
- B. Integrity — the message must not be modified, inserted into, or deleted while in transit.
- C. Authentication — each party must be able to verify that the other is who they claim to be.
- D. Availability — the information or service must remain reachable to legitimate users.

Correct answer: **C**

Why: Authentication ensures each party can verify the other is who they claim to be. Impersonating an entity on the network defeats authentication; identity-verification mechanisms are the countermeasure.

Q4. [MCQ]

Scenario: An attacker directs a botnet to flood a company's web server with a denial-of-service attack. The server is overwhelmed and legitimate customers can no longer reach the site. The traffic is neither read nor modified. Which property of secure communication is violated?

- A. Confidentiality — only the two communicating parties should be able to read the message.
- B. Integrity — the message must not be modified, inserted into, or deleted while in transit.
- C. Authentication — each party must be able to verify that the other is who they claim to be.
- D. Availability — the information or service must remain reachable to legitimate users.

Correct answer: **D**

Why: Availability ensures the information or service remains reachable to legitimate users. Denial-of-service attacks that render the system unreachable break availability, independent of confidentiality or integrity.

Q5. [MCQ]

Consider the properties of a secure communication. Which property is most directly threatened by a successful Denial-of-Service attack?

- A. Availability — the service or information becomes unreachable to legitimate users.
- B. Confidentiality — the attacker reads the plaintext of every message.
- C. Integrity — the attacker modifies messages in flight.
- D. Authentication — the attacker impersonates the server's identity to clients.

Correct answer: **A**

Why: DoS attacks Availability (A in CIA). The service can't be reached by legitimate users; confidentiality and integrity remain intact (the attacker isn't reading or modifying anything, just denying access).

DNS Abuse

Q6. [MCQ]

What is Round-Robin DNS (RRDNS), the legitimate technique that DNS abuse builds upon?

- A. A method that answers a lookup with a list of A records and cycles through them, distributing incoming load across several servers at a single location.
- B. A method that encrypts DNS responses so only the intended client can read the returned IP address.
- C. A protocol that cryptographically signs the (domain, IP) mapping to prevent spoofing.
- D. A routing technique that announces the same prefix from many ASes to balance traffic.

Correct answer: **A**

Why: RRDNS answers a lookup with a list of A records and cycles through them round-robin, spreading load across multiple servers at one site; each record carries a TTL, and repeated lookups within the TTL return the same set. It is a benign load-distribution technique that FFSN later abuses.

Q7. [MCQ]

Considering the context of domain abuse, what is the ULTIMATE goal that attackers pursue by abusing the DNS protocol?

- A. To extend the uptime of domains used for malicious purposes and remain undetectable for longer.
- B. To encrypt malicious traffic end-to-end so it cannot be read in transit.
- C. To reduce the latency of legitimate CDN content for paying customers.
- D. To obtain valid RPKI certificates for the attacker's prefixes.

Correct answer: **A**

Why: The lesson states the goal of DNS abuse is to extend the uptime of malicious domains (C&C, phishing, spam, illegal content/business hosting) and stay undetectable longer. It is about the survivability of the malicious infrastructure, not confidentiality or performance.

Q8. [TF]

A key motivation for DNS abuse is supporting the INFRASTRUCTURE attackers rely on — e.g., command-and-control (C&C) hosting, phishing and spam domains, and hosting of illegal content or businesses.

- True
- False

Correct answer: **True**

Why: The lesson frames DNS abuse around the malicious infrastructure it protects: C&C hosting, phishing/spam domains, and illegal content/business hosting. Keeping that infrastructure reachable and hidden for as long as possible is exactly what the abuse buys.

Q9. [MCQ]

Legitimate RRDNS and CDNs return MULTIPLE A records (several IPs) for reliability. Why does the same behavior become a strategic ADVANTAGE for a spammer running a scam?

- A. Multiple A records let the attacker encrypt each response differently, hiding the content.
- B. If even one of the returned IPs is still functional, the scam keeps working — and spreading it across many servers makes coordinated shutdown much harder.
- C. Multiple A records force resolvers to cache the domain forever, so it can never be removed.
- D. Returning several IPs lowers the attacker's bandwidth cost to nearly zero.

Correct answer: **B**

Why: The redundancy that gives legitimate sites reliability gives scams resilience: as long as one returned IP works, the scam is up, and distributing it across many servers makes takedown complex. That resilience is precisely the strategic advantage DNS abuse offers.

Q10. [MCQ]

DNS abuse often relies on very short TTLs. Consider the scenario: a victim visits a malicious domain served by an FFSN, and the DNS A-record returns a different IP every few seconds (low TTL). What does this rotation achieve for the attacker?

- A. Each lookup encrypts the DNS response, making detection difficult.
- B. The attacker can claim ownership of every IP returned and bill each IP's owner.
- C. No single IP is critical — taking down one flux agent does not take the site offline, because the next lookup hands the victim a fresh agent.
- D. The low TTL forces resolvers into anycast mode, so they co-announce the malicious prefix and share the hosting load.

Correct answer: **C**

Why: Low TTL -> constantly rotating IPs -> resilience. Killing one flux agent doesn't kill the site; the next lookup returns a new agent, so defenders must take down many agents (or seize the domain) rather than one IP. This resilience is the core advantage DNS abuse buys the attacker.

Q11. [MCQ]

FFSNs are an example of DNS abuse that faces a TRADE-OFF between flux speed and stealth. Which best describes it?

- A. Flux agents must all be in the same AS or they are detected together.
- B. Lower TTL means longer uptime per IP, so defenders can blacklist each agent once and permanently dismantle the network.
- C. Higher TTL is worse for the attacker because it lets defenders blacklist each IP for longer.
- D. Faster domain rotation (very low TTL) makes the network harder to take down but produces DNS query patterns unlike benign hosting — so the very mechanism that gives resilience is itself a detectable signal.

Correct answer: **D**

Why: Faster rotation = more resilient BUT more anomalous. Extreme low TTLs and high IP churn look nothing like benign hosting, so defenders detect the abuse using the very signal that gives it resilience.

Q12. [TF]

DNS-abuse techniques such as FFSN are not new protocols — they build on the same legitimate DNS mechanisms (round-robin DNS, CDN-style delivery) that real businesses use; what distinguishes the abusive case is the very low TTL and the rotation across compromised hosts.

- True
- False

Correct answer: **True**

Why: DNS abuse twists legitimate techniques. RRDNS and CDN DNS-based delivery are benign; FFSN reuses them but with much lower TTL and a rotating set of compromised machines. The mechanism is legitimate — the abuse is in how it is used.

Q13. [TF]

In an FFSN the flux agents, though they appear to act together as one site, are typically spread across different countries and different Autonomous Systems — which makes coordinated takedown harder for defenders.

- True
- False

Correct answer: **True**

Why: The lesson notes flux agents are usually located in different countries and belong to different ASes. This geographic and administrative spread means no single ISP or jurisdiction can shut the whole operation down, adding to the abuse's resilience.

Q14. [MCQ]

FFSN is an extension of RRDNS and CDN ideas. What is the KEY difference that makes it abusive rather than legitimate?

- A. FFSN uses a HIGHER TTL than RRDNS so mappings stay valid much longer.
- B. After the TTL expires, FFSN returns a DIFFERENT set of A records drawn from a large pool of COMPROMISED machines, using a TTL even lower than RRDNS/CDN.
- C. FFSN abandons DNS entirely and hard-codes IP addresses into the malware.
- D. FFSN serves content directly from the authoritative DNS server rather than from a web server.

Correct answer: **B**

Why: Legitimate RRDNS/CDN return a fairly stable set of records; FFSN uses an even lower TTL and, crucially, hands back a DIFFERENT set of IPs each time from a large set of COMPROMISED machines acting as proxies to the mothership. The rapid change over compromised hosts is what turns a legitimate technique into abuse.

How to Infer Network Reputation: Evidence of Abuse

Q15. [MCQ]

How does the system FIRE ('FInding Rogue nEtworks') decide whether an AS is rogue?

- A. It combines lists of malicious IPs (botnet C&C, drive-by-download hosting, phishing) and ranks ASes by the ratio of malicious to owned IPs.
- B. It counts the number of BGP UPDATE messages each AS sends per second, flagging any AS whose update rate exceeds that of its peers as rogue.
- C. It inspects every packet flowing through every AS for malware signatures.
- D. It looks at the year the AS number was first allocated to the operator.

Correct answer: A

Why: FIRE ranks ASes by malicious-IP RATIO from abuse lists. Combines botnet C&C lists, phishing hosting, drive-by lists — and divides by the AS's IP holdings so small bad-ASes aren't drowned out by big ones.

Q16. [TF]

FIRE focuses on EVIDENCE OF ABUSE — observed malicious activity originating from an AS — rather than on the AS's organizational structure or business contracts.

- True
- False

Correct answer: True

Why: Evidence of abuse — observed malicious activity from the AS. FIRE doesn't care about business contracts or organizational structure; it cares about what's actually happening on the wire.

How to Infer Network Reputation: Interconnection Patterns

Q17. [MCQ]

Consider inferring network reputation from CONTROL-PLANE features (e.g. ASWatch). Which feature family is NOT used by these approaches?

- A. Rewiring activity (frequent provider changes).
- B. Per-packet payload inspection of traffic crossing the AS.
- C. IP space fragmentation and churn in advertised prefixes.
- D. BGP routing dynamics (announce/withdrawal patterns).

Correct answer: **B**

Why: Per-packet payload inspection is NOT one of ASwatch's features. ASwatch is entirely control-plane (BGP-visible) — rewiring, IP-space fragmentation, BGP announce/withdraw dynamics.

Q18. [MCQ]

Consider the following scenario: an AS shows frequent provider changes shortly before observable malicious activity. How does ASwatch interpret this?

- A. Rewiring proves the AS is innocent because a new provider would have refused a known bad customer, so ASwatch treats each change as a positive reputation signal.
- B. Rewiring is benign administrative behavior and is ignored by ASwatch.
- C. Rewiring is itself a signal — malicious operators often switch providers to avoid being shut down, so unusually frequent rewiring before/around abuse is suspicious.
- D. Rewiring activity is the only feature ASwatch uses; all others are removed by feature selection.

Correct answer: **C**

Why: Frequent rewiring before abuse = suspicious signal. Malicious operators switch providers to escape shutdown; legitimate operators don't change transit providers monthly.

Q19. [MCQ]

Consider network reputation systems that only use control plane features, what do they ultimately produce?

- A. A new BGP attribute that, once attached to routes, makes the rogue AS unroutable.
- B. A definitive cryptographic proof that an AS is malicious, sufficient to revoke its ASN automatically.
- C. A list of malicious packets observed at every IXP in the world that day.
- D. A reputation score for each AS, derived from a model trained on labeled data, that can be used to flag suspicious networks for further attention.

Correct answer: **D**

Why: ASwatch outputs a reputation SCORE per AS. Features are fed into a classifier trained on labeled data; the output is a number flagging suspicious networks for human review, not an automatic ban.

Q20. [TF]

Consider network reputation systems that operate EXCLUSIVELY on control-plane signals (BGP-visible behaviour) — these systems do not inspect packet payloads or data-plane content.

- True
- False

Correct answer: **True**

Why: ASwatch is control-plane only (BGP signals). No packet inspection — it relies on public BGP feeds, route databases, IP allocations, and rewiring history.

How to Infer Network Reputation: Likelihood of Breach

Q21. [MCQ]

Suppose a model claims ~90% accuracy at predicting whether an organization will suffer a breach. Why can that headline accuracy number be misleading when the model is deployed?

- A. Accuracy is a poor summary on imbalanced data — in any given window most organizations do not suffer a breach, so a model that almost always predicts "no breach" can reach ~90% accuracy while offering little operational value.
- B. Tree-ensemble models are known to overfit and rarely generalize, so the 90% only reflects memorized training organizations and collapses to random guessing on unseen networks.
- C. The model relies solely on internal signals (e.g., logs, patch state) that an external defender cannot observe in practice, so the number cannot be reproduced.
- D. The 90% figure assumes BGP Flowspec is deployed inter-domain at scale, which is not the case today.

Correct answer: **A**

Why: With a rare/imbalanced positive class, headline accuracy is dominated by the majority "no-breach" class — a trivial "predict no breach for everyone" model scores ~90% while being useless. Precision, recall, and base rate are what matter in deployment. B/C/D are plausible-sounding but wrong: they misattribute the problem to overfitting, feature observability, or an unrelated routing mechanism.

Q22. [TF]

On a heavily skewed binary classification problem, accuracy alone is not sufficient to evaluate a model's usefulness — operators care about precision, recall, and threshold-dependent trade-offs.

- True
- False

Correct answer: **True**

Why: Imbalanced data => accuracy != usefulness; need precision/recall/threshold trade-offs. Operators tune their threshold based on cost of false positives vs false negatives, not just raw accuracy.

Traffic Attraction Attacks: BGP Hijacking

Q23. [MCQ]

What is a 'sub-prefix' BGP hijack, and why could it lead to LARGE traffic attraction attacks?

- A. The hijacker announces the SAME prefix as the legitimate origin; ASes pick one at random, biased toward the hijacker, so with no longest-prefix match to break the tie the rogue route wins across half the Internet.
- B. The hijacker announces a more-specific prefix than the legitimate origin; BGP best-path selection prefers more-specific prefixes via longest-prefix match, so most of the Internet adopts the rogue route.
- C. The hijacker announces a SHORTER prefix that covers the legitimate one; longer prefixes are silently dropped at every router.
- D. The hijacker announces a DIFFERENT prefix unrelated to the victim, and the victim suffers collateral congestion.

Correct answer: **B**

Why: Sub-prefix hijack: more-specific prefix wins via LPM. The hijacker announces a /24 inside the victim's /16; longest-prefix-match means every router forwards to the more-specific (hijacker), redirecting essentially all traffic.

Q24. [MCQ]

Consider an origin AS hijacking attack, select the statement that best represents it?

- A. The hijacker modifies the destination AS in the AS-PATH while leaving the prefix unchanged.
- B. The hijacker inserts a fake link two hops from the rightmost position of the AS-PATH.
- C. The hijacker originates a prefix they do not own, without inserting any fake link in the advertised AS-path.
- D. The hijacker deaggregates their own prefix to attract more traffic.

Correct answer: **C**

Why: Type-0 = origin hijack: just announce a prefix you don't own. No AS-PATH forgery; the hijacker simply originates the victim's prefix from its own ASN — the simplest, most easily detected variant.

Example BGP Hijack Attacks

Q25. [MCQ]

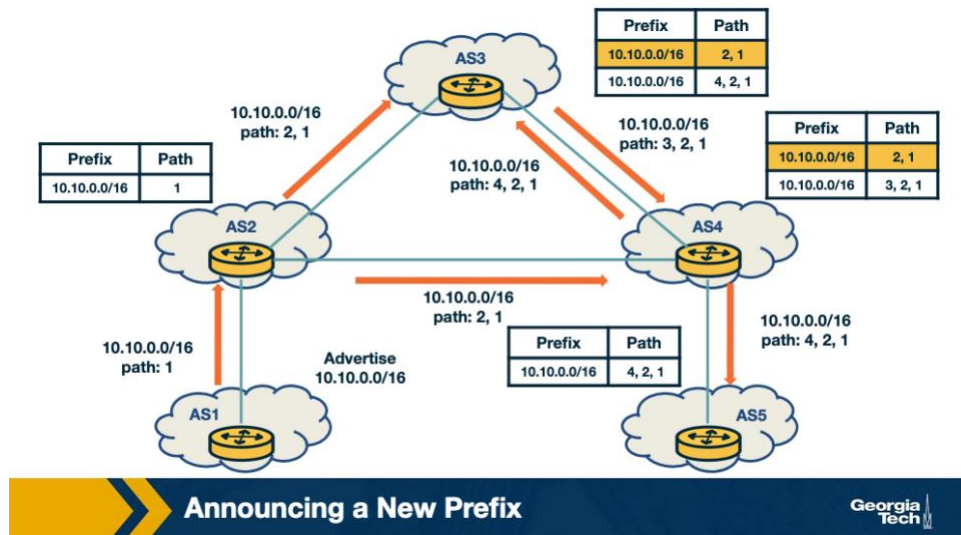


Figure: BGP hijack example — legitimate scenario, AS1 origin (Module 9)

In the legitimate scenario shown: AS1 announces 10.10.0.0/16. AS2, AS3, AS4 propagate it. What path does AS5 finally adopt for this prefix?

- A. (5,3,1) — AS5 prefers AS3 over AS4 because its path length is lower in this topology.
- B. (5,1) — AS5 has a direct neighbor relationship with AS1.
- C. (4,2,1) — AS5 learns the full path through AS4 from AS2 and AS1.
- D. AS5 receives no announcement in this scenario.

Correct answer: C

Why: Legitimate scenario: AS5 adopts (4,2,1) — it receives the full path from AS4. With no hijack, normal BGP propagation gives AS5 the route via AS4→AS2→AS1, exactly the (4,2,1) the figure shows.

Q26. [MCQ]

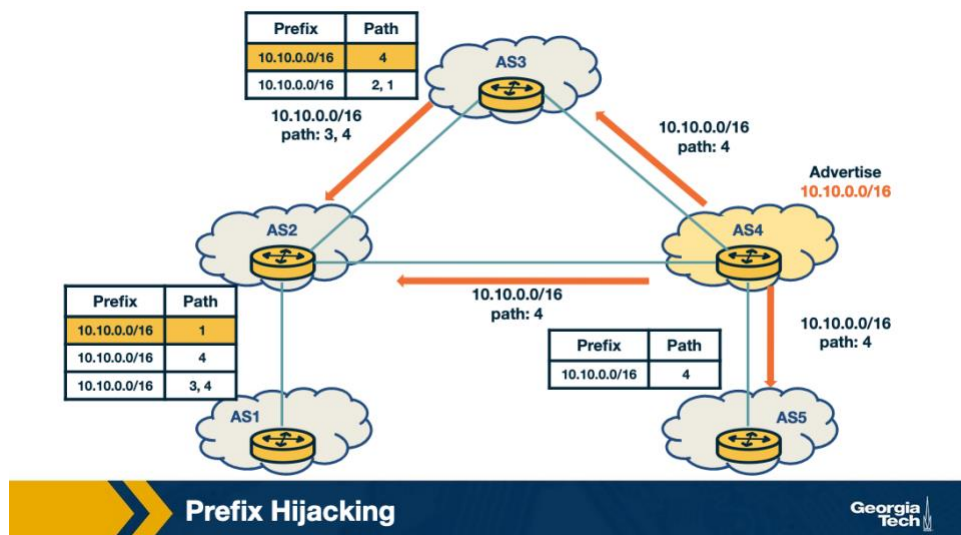


Figure: BGP prefix hijack — attacker AS4 (Module 9)

In the prefix-hijack figure: attacker AS4 announces 10.10.0.0/16 with origin AS4. Which AS in the figure does NOT switch to the hijacked route, and why?

- A. AS1 — AS1 ignores updates about its own prefix.
- B. AS5 — AS5 has no path to AS4 in this topology.
- C. AS3 — AS3 filters updates originating from AS4 by an inbound routing policy and so does not install the hijacked route.
- D. AS2 — the false route has the same path length as AS2's existing entry to AS1, so AS2 does not prefer the new route.

Correct answer: **D**

Why: AS2 doesn't switch: the hijacked route via AS4 has the same AS-PATH length as AS2's existing entry (path 1 vs path 4, both one hop), and on a tie a router keeps its current best path. Only ASes where the false path is shorter switch — AS3 (4 beats 2,1) and AS5. Note on distractor A: AS1 is indeed unaffected, but not because of AS-PATH loop prevention. This is a Type-0 origin hijack — AS4 emits path {4}, so AS1's ASN never appears and the loop check never fires. AS1 is protected instead because it doesn't need BGP to reach its own prefix: 10.10.0.0/16 is locally originated, living in AS1's IGP / connected routes with more-specific subnets underneath. Longest-prefix match means an internal 10.10.5.0/24 beats any /16 a neighbor hands it, and in the BGP decision process a locally-originated route beats an eBGP-learned one at the first tiebreaker, before AS-PATH length is consulted. So AS1 keeps forwarding correctly internally — what it loses is inbound traffic from the rest of the Internet. Its routing table looks perfectly healthy and it has no local symptom to alarm on. That asymmetry is the point of the slide: the victim is often the last to know, and detects the hijack only through outside observation (route collectors, RIPE RIS/RouteViews, third-party monitoring) or a traffic-volume drop.

Q27. [MCQ]

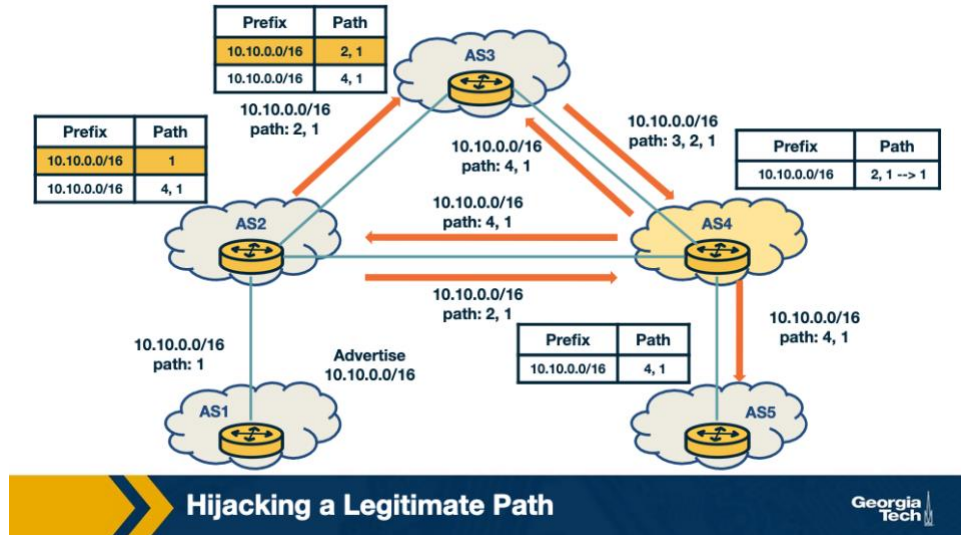


Figure: Hijacking a path — AS4 forges path (4,1) (Module 9)

In the path-hijack scenario shown in the figure: AS4 advertises a path (4,1) claiming a direct link to AS1. Per the figure, which AS believes and adopts the false path?

- A. Only AS5 adopts (4,1); AS2 and AS3 keep their existing shorter or equal-length path to AS1.
- B. All of AS2, AS3, and AS5 adopt (4,1) because BGP cannot validate links.
- C. Only AS2 adopts (4,1); AS3 and AS5 reject it for unspecified reasons.
- D. No AS adopts (4,1) — BGP rejects all forged direct links automatically.

Correct answer: **A**

Why: AS5 adopts (4,1) — only it sees the forged shorter path. AS5's existing path was longer; the fake direct link makes (4,1) appear two hops away, so AS5 switches.

Defending against BGP Hijacking: Example Mitigation Techniques

Q28. [MCQ]

A victim network defends against a BGP prefix hijack using prefix deaggregation. How does this technique counteract the hijack?

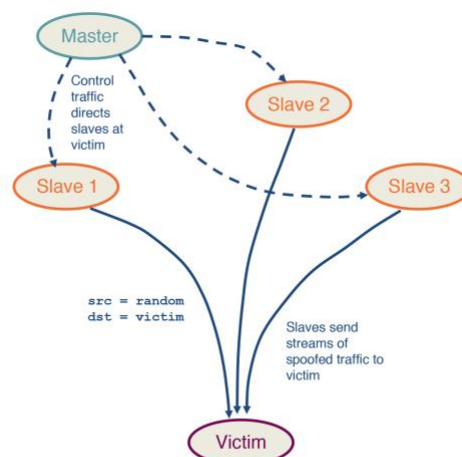
- A. It announces more-specific sub-prefixes of the targeted prefix, so longest-prefix match pulls traffic back toward the legitimate origin.
- B. It withdraws the targeted prefix and waits for the hijacker's route to age out of the RIBs across the Internet.
- C. It cryptographically signs the (prefix, origin-AS) mapping so receiving ASes automatically reject the rogue announcement.
- D. It prepends its own AS several times to the announcement so its route wins on a longer, more-trusted AS-path.

Correct answer: **A**

Why: Prefix deaggregation means the victim announces more-specific prefixes than the hijacked block (e.g., splitting a hijacked /24 into two /25s). Because routers everywhere prefer the longest matching prefix, traffic is drawn back to the legitimate origin regardless of which tool automates the response. B — a withdrawal doesn't reclaim already-diverted traffic; the hijacker's route stays selected. C — that's origin validation / route signing (RPKI-style), a different defense, not deaggregation. D — AS-path prepending lengthens the path, making a route less preferred — the opposite of what's needed.

DDoS: Background and Spoofing

Q29. [MCQ]



Reference Figure from Canvas Module: DDoS structure — master/slaves/victim with spoofed sources (Module 9)

Consider a DDoS attack as shown in the reference figure - what addresses do the slaves place in the source and destination fields of the flood packets sent to the victim?

- A. Source: the master's IP. Destination: the victim's IP.
- B. Source: the slave's real IP. Destination: the victim's IP.
- C. Source: the victim's IP. Destination: the master's IP.
- D. Source: a random/spoofed IP. Destination: the victim's IP.

Correct answer: **D**

Why: Spoofed source + victim destination. Slaves forge their source IP to make traceback hard and to enable reflection; the destination is always the victim.

Q30. [TF]

A DDoS attack threatens the AVAILABILITY property of secure communication, but not necessarily confidentiality or integrity.

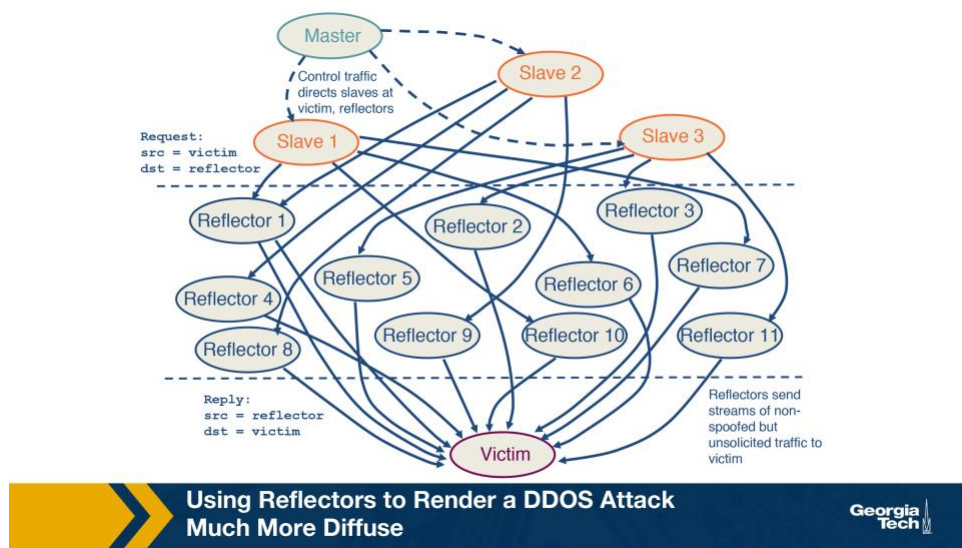
- True
- False

Correct answer: **True**

Why: DDoS attacks Availability only. Confidentiality and integrity are unaffected — the attacker isn't reading or modifying traffic, just preventing the victim from serving legitimate requests.

DDoS: Reflection and Amplification

Q31. [MCQ]



Reference Figure from Canvas Module: Reflection and amplification — slaves spoof victim's IP toward reflectors (Module 9)

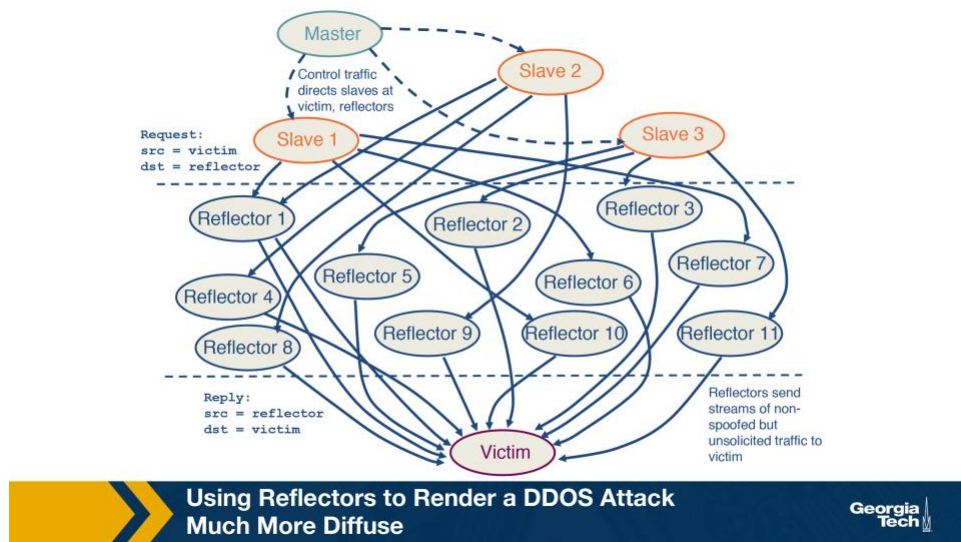
In the reflection-attack shown in the reference figure, what is the role of the 'reflector'?

- A. A compromised slave host that attacks the victim directly without any spoofing, flooding the target straight from its own real source IP at full rate.
- B. Any server (DNS, NTP, memcached, ...) that responds to a request — slaves send it spoofed requests with the victim's IP as the source, so the response hits the victim.
- C. A scrubbing service that filters attack traffic away from the victim.
- D. An IXP route server that propagates blackhole community tags.

Correct answer: **B**

Why: Reflector = any responding server; slave spoofs victim's IP as source. The slave's request looks like it came from the victim, so the reflector's response goes to the victim.

Q32. [MCQ]



Reference Figure from Canvas Module: Reflection attack — diffuse traceback (Module 9)

In the reflection-attack shown in the reference figure, why is it harder for the victim to TRACE BACK to the slaves in a reflection attack than in a direct DDoS?

- A. IXPs anonymize all traffic that passes through them.
- B. Reflectors strip the IP TTL field from every packet they respond to, erasing the hop count the victim would otherwise use to triangulate the slaves.
- C. The victim sees responses from reflectors; reflectors received spoofed requests, so the reflector itself cannot identify the slave that sent it.
- D. Slaves use TLS to reach reflectors, hiding their identity even from each other.

Correct answer: **C**

Why: Reflectors saw spoofed requests => cannot identify true slave. The victim sees only the reflector's IP; the reflector has no idea which slave forged the request — traceback breaks down.

Q33. [MCQ]

What does 'amplification' add to a reflection attack?

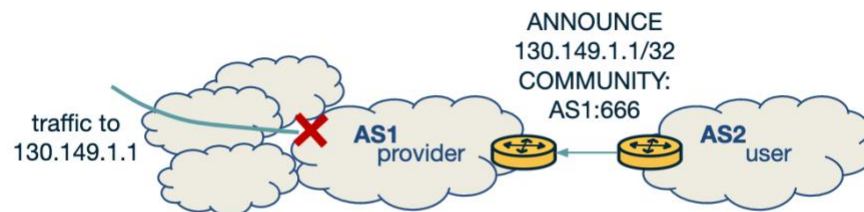
- A. Amplification refers to TCP congestion control increasing cwnd; it has no role in DDoS.
- B. Amplification increases the victim's tracing capability, which is why attackers avoid it.
- C. Amplification only increases the request size, not the response, so the attack grows less effective and forces the attacker to spend more bandwidth than the victim receives.
- D. The reflector's response is much larger than the request, so a small spoofed request triggers a large response toward the victim — multiplying the attacker's bandwidth.

Correct answer: **D**

Why: Amplification = response >> request size. DNS (x54), NTP (x556), memcached (x50,000+) let a small spoofed request trigger a huge response, multiplying the attacker's bandwidth.

DDoS Mitigation Techniques: BGP Blackholing

Q34. [MCQ]



(a) Provider-based blackholing



Reference Figure from Canvas Module: BGP blackholing — upstream provider drops traffic into a null interface (Module 9)

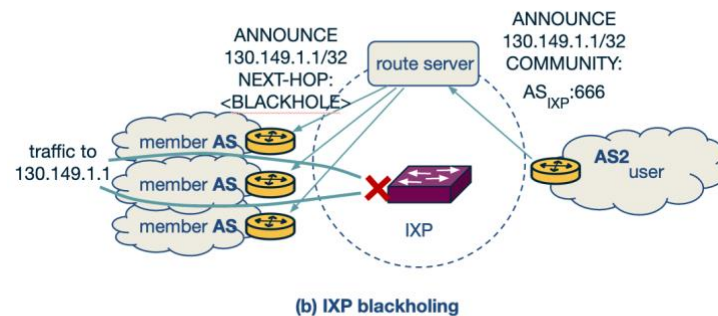
In the blackholing reference figure, host 130.149.1.1 in AS2 is under attack. Which message does AS2 send to AS1, and what does AS1 do?

- A. AS2 sends 130.149.1.0/24 with a community AS1:42 and AS1 simply re-advertises it to its peers.
- B. AS2 announces 130.149.1.1/32 with the blackhole community (e.g., AS1:666); AS1 sets the next-hop to a blackhole IP and drops all traffic to that host.
- C. AS2 sends a Flowspec rule rate-limiting UDP/11211; AS1 installs the rule.
- D. AS2 withdraws its entire prefix and AS1 propagates the withdraw across all peers.

Correct answer: **B**

Why: BGP blackhole: AS2 announces /32 with blackhole community; AS1 null-routes that /32. The community tells AS1 'drop everything to this address'; AS1 sets next-hop to a black-hole interface and discards.

Q35. [MCQ]



What is BGP Blackholing?

Reference Figure from Canvas Module: BGP blackholing — granularity and effect (Module 9)

In the IXP-based BGP blackholing scenario, the victim AS sends a blackholing message (tagged with the IXP's blackhole community) to the IXP route server, which advertises it to all member ASes. Why is the blackholed prefix TYPICALLY a /32 host route rather than the victim's larger network prefix?

- A. A /32 confines the drop to the single host IP under attack, so the rest of the victim's prefix keeps receiving legitimate traffic; blackholing the larger prefix would null-route legitimate services too (collateral damage).
- B. A /32 lets the route server drop only the attack traffic (e.g., the UDP amplification port) while still forwarding traffic on legitimate ports like 80/443.
- C. The IXP route server only accepts more-specific routes, so a /32 is required for its announcement to win over the victim's own /24 by longest-prefix match.
- D. A /32 causes the drop to happen at the attack's source networks, whereas a larger prefix would only drop traffic at the victim's own edge.

Correct answer: **A**

Why: A /32 confines the null-route to the single host IP under attack, so the rest of the victim's prefix keeps serving legitimate traffic; blackholing the larger prefix would drop legitimate services too (collateral damage). B is the tempting one — it echoes the limitations page's "ideal solution" (block only UDP 11211). But blackholing is destination-prefix-based and drops all traffic to that IP regardless of port; port-selective filtering is exactly what it cannot do. Prefix length doesn't change that. C uses a true fact (a /32 does win by longest-prefix match) as a false reason — the route server doesn't require more-specifics, and LPM isn't why operators choose /32; collateral-damage containment is. D conflates prefix granularity with drop location. "Stopped closer to the source" is a real lesson point, but it depends on where members drop, not on /32 vs /24.

Q36. [TF]

BGP blackholing PROTECTS the upstream network from collateral damage at the cost of making the targeted host unreachable — i.e., the attacker still achieves availability denial for that host.

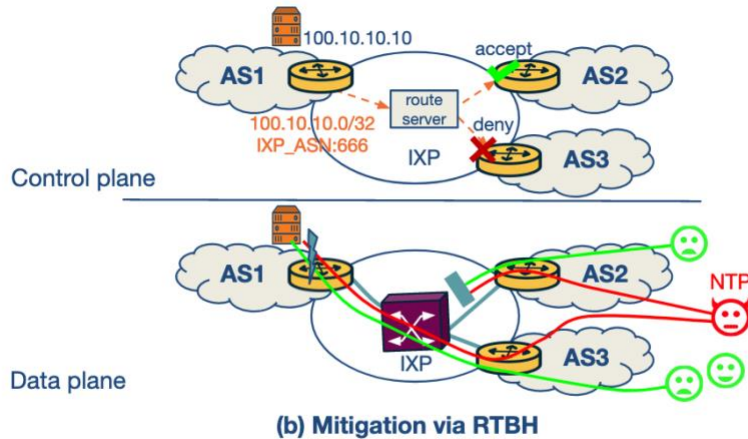
- True
- False

Correct answer: **True**

Why: Blackhole drops attacker AND victim's legitimate traffic => availability denial achieved anyway. The defender chose collateral damage over total network meltdown; the attacker still wins for that host.

DDoS Mitigation Techniques: BGP Blackholing Limitations and Problems

Q37. [MCQ]



Blackholing Limitations and Problems

Georgia Tech

Reference Figure from Canvas Module: Blackholing limitations — partial adoption among neighbors (Module 9)

Consider the scenario shown in the reference figure: prefix 100.10.10.0/24 is announced by AS1, host 100.10.10.10 is under attack, AS2 accepts the IXP blackhole update but AS3 rejects it. What is the resulting effect?

- A. The IXP withdraws the announcement, restoring service.
- B. AS3 automatically blackholes the prefix because the IXP route server forces it.
- C. All attack traffic is dropped at AS3 even without explicit blackholing, because AS3's rejection of the IXP update automatically installs a discard route for the whole 100.10.10.0/24 prefix.
- D. All traffic via AS2 to 100.10.10.10/32 (including legitimate traffic) is dropped; AS3 still forwards both legitimate and attack traffic. If most attack traffic comes via AS3, mitigation is ineffective.

Correct answer: **D**

Why: Partial adoption => traffic via non-blackholing peers reaches victim. Blackholing works only on the paths that honor it; an attacker entering via a non-cooperating peer goes straight through.

Q38. [TF]

Partial adoption of blackholing across the operator's neighbors is itself a limitation: traffic that arrives via non-blackholing peers still reaches the victim.

- True
- False

Correct answer: **True**

Why: Partial adoption is itself a limitation. Traffic via non-blackholing peers still reaches the victim; effective mitigation needs broad peer cooperation.